

Cross-Document Reconciliation + Consolidated Operator-Decision Register — Multi-Account Research Set

Revision: 1 Last modified: 2026-07-10T11:18:54Z

Scope. This document performs the §11.4.186 **CROSS-DOC + INTEGRITY** consistency pass over the multi-account to-be research set (20_...27_) and consolidates the still-open operator decisions into one approval-gate register. It is a **reconciliation report, not a rewrite**: per §11.4.186 it *finds and records* divergence — it does **not** silently edit any source doc. The only file written under this task is this one (28_*).

SSOT. 20_target_multitenancy_data_model.md is the declared single source of truth for entity / claim / column shapes; 21_authz_rbac_superuseradmin.md owns the permission-model shape + token-claim + role-vocabulary reconciliation (OQ-2); 22_api_surface.md owns the route shapes + the path-vs-token scoping decision; 26_security_threat_model.md owns the per-account signing-key threat/registry. 23_/24_/25_ were authored **before** 20_ landed and their explicitly-marked **illustrative** shapes are the primary reconciliation targets; 21_/22_/26_/27_ were authored **after** 20_ and cite it.

Reading order. 00_INDEX.md (mandate + OQ-1...OQ-4) → 10_/11_/12_ (as-is) → 20_ (entity SSOT) → 21_/22_ → 23_/24_/25_ → 26_/27_. Every divergence claim below is grounded in a doc §section or a file:line those docs established; no new external research was performed (§11.4.99 — this is an internal-consistency pass).

1. Divergence audit (§11.4.186 CROSS-DOC + INTEGRITY families)

Method: for each entity / claim / role / endpoint that appears in more than one doc, verify the pre-SSOT docs (23_/24_/25_) and the post-SSOT docs (21_/22_/26_) agree with 20_ (SSOT). Status vocabulary: **CONSISTENT** (no action) · **RECONCILE** (low-risk wording/name/citation alignment) · **RESIDUAL-BLOCKING** (a real contradiction that MUST be fixed before implementation).

1.1 The five explicitly-mandated cross-checks

#	Item	Authoritative source
Token claim set		
A	{sub,roles,iat,exp} + account_id/ project_id	20_ §2.2 #7 (defers token shape to 21_); 21_ §3 (defines the cla
B	Account shape	20_ §1.1 (account_id,name,slug,status,created_at,updated_at)
C	User shape	20_ §1.2 (user_id,username,email,password_hash,is_super_admin,is_acti

#	Item	Authoritative source
D	Membership shape	20_ §1.3 AccountMembership{AccountID,UserID,Role,IsOwner} / table account_members (composite PK (user_id,account_id))
E	Role vocabulary	20_ §1.4 Membership.role ∈ {viewer,operator,admin}; 21_ §5.1 token-roles set {viewer,operator,admin,device,super_admin} (server token.go = SSOT)
F	Account-scoping approach (path vs token-claim)	22_ §2.0 (decides: token-claim on the hot path, path-based on for the admin cross-account API)

#	Item	Authoritative source
G	Per-account signing keys	26_ §4 (per-account key REGISTRY keyed on resolved account_id, global fallback, verify-key-from-config-only)

1.2 Additional divergences found during the pass (not in the mandated five)

#	Item	Authoritative source	Divergent doc:section	Threat
H	api_keys.project_id scope column	20_ §4 (SSOT api_keys DDL)	21_ §6.1; 22_ §4.1; 24_ §1.1	21_ bi ac op ec (“ ac n sc 24_ §1 pr ov A ap as br ac (2 40

#	Item	Authoritative source	Divergent doc:section	Th
				on on en SS an do a do O re fo re §3 O cl no is ac ro ex ex th fa is sp ex ho (n ac ho re de de fo “f tr + i.e re
J	Legacy-token (no account_id claim) handling	21_ §3.3 (authZ SSOT; 22_ cedes authZ to it, 22_ Honest-boundary)	22_ §6.1	
I		20_ §4 (api_key_id)		

#	Item	Authoritative source	Divergent doc:section	TL
	api_keys PK column name		24_ §0 / §1.1 (id, quoting the 001_initial_schema.up.sql:57-71 sketch)	24_ SS co 20_ PR N co §1 re re in st Co th us na TL ra sa IN “s di re (n ev th ve se
K	Id type — TEXT vs UUID	20_ §1 (self-flags + resolves: impl seam = opaque TEXT mirroring the shipped store; canonical 001-style schema keeps UUID; §4 states the TEXT ↔ UUID mapping)	24_ §0/§1.1 cite the UUID-oriented 001 sketch for api_keys columns	
L	resolvePublicKey file:line citation	The one function handlers_artifact.go	20_ §6 / 21_ §1.4 / 22_ §1.2,§4.1 = 274-283; 24_ §0,§3 / 25_ §5 = 283-288; 26_ §0,§4 = 274-288	

1.3 The two load-bearing residuals (must fix before implementation)

- **#H — api_keys.project_id absent from the SSOT DDL.** The project-CLI’s entire “account-scoped, optionally project-narrowed key” model (24_ §1.1, 21_ §6.1, 22_ §4.1) — including “NULL project_id = any project in the account” — has no column to live on in 20_ §4. Left unfixed, implementers would either invent the column ad hoc (re-introducing the divergence §11.4.186 forbids) or

drop project-narrowing silently. Fix is a one-line additive column in 20_ §4.

- #J — **legacy-token handling contradiction.** 21_ (fail-closed) and 22_ (default-account fallback) prescribe **opposite security postures** for a legacy token on a scoped route. This is precisely the “same tracked data, two divergent representations” §11.4.186 exists to catch: shipping both as-written yields either a fail-closed *or* a silently-scoped-to-__default__ route depending on which doc the implementer follows. 22_ cedes authZ to 21_, so 21_ §3.3 Option A wins.

2. Consolidated operator-decision register (approval-gate)

The single table to act on at the approval gate. Each decision is presented with its options, the design’s recommendation + rationale, blast-radius/reversibility, and the milestone it gates (sequenced by the delivery plan 30_, planned per 00_INDEX §3).

#	Decision (source)	Options	Design recommendation + rationale	Blast-radius / reversibility	
1	OQ-1 — “OpenCode” vs OpenDesign (00_INDEX §5; resolved 12_, carried 23_ Honest-boundary as UNCONFIRMED)	(a) OpenCode = the coding agent used to BUILD UI (3299 hits, only in llm_orchestrator/vision_engine adapters, zero UI hits); OpenDesign = the mandated design-token system (§11.4.162) the built UI CONSUMES (already vendored design-systems/helix-ota/). (b) some other tool	Confirm (a). Evidence-grounded in 12_; both statements are simultaneously true, flagged only because the mandate used the literal word “OpenCode” (§11.4.66).	Near-zero; a naming clarification. Fully reversible.	
2	OQ-2 — permission-model shape	(a) pure tenant-scoped RBAC; (b) full ABAC policy engine (Cedar/	Adopt (c), delivered RBAC-first (21_ §1.2): a 3-step decision — tenant-isolation	High design reach (the whole authZ stack) but	

#	Decision (source)	Options	Design recommendation + rationale	Blast-radius / reversibility	C
	(00_INDEX §5; owner 21_ §1)	OPA/Cerbos); (c) role+scope hybrid	predicate (first) → RBAC role×resource matrix (the shipped RESOURCE_PERMISSIONS grid promoted server-authoritative) → thin ABAC deny-override (suspended account / inactive user / revoked key). Reuses the shipped role hierarchy + rank tooling verbatim; closes the cross-account hole by construction; grows to custom-per-account roles via 20_ §1.4's reserved roles/permissions/role_permissions tables with no second data-model change. (a) local super-admin-provisioned users for now. The directive implies it (00_INDEX §1.2 — no self-registration), and 20_ §1.2 User.password_hash models local credentials; no to-be doc designs federation. Federation is a future escalation (a User identity-provider column +	reversible-additive: fixed enum now, reserved tables ship as commented DDL, full ABAC engine stays a documented future escalation. Moderate; local-first is additive-compatible with later federation (User gains an external_idp/subject column; no rework of the account/membership model).	
3	OQ-3 — identity source (00_INDEX §5)	(a) local accounts only (super-admin-provisioned); (b) federated (OIDC/SAML)			

#	Decision (source)	Options	Design recommendation + rationale	Blast- radius / reversibility	
4	OQ-4 — migrate existing data under accounts (00_INDEX §5; owner 20_ §5)	(a) default-account backfill (big-bang → NOT NULL); (b) additive- nullable-until-backfill (gradual)	an IdP seam) — flag for the operator if a launch IdP is required. (a) default-account backfill (20_ §5): 002 adds account_id nullable → backfill every legacy row to a seeded __default__ account → 003 sets NOT NULL + per- account uniques + composite FKs + leading-column indexes + enables RLS. Removes the nullable-isolation- hole window entirely; near-free because the store is an in-memory MVP barely populated. Flip to (b) only if a target already holds meaningful prod data AND zero- downtime is mandatory (accept the interim NULL- scoping window, super-admin-only visibility). Couples to #J: whichever is chosen, a legacy <i>token</i> is fail-closed (21_ §3.3), not mapped to __default__.	One coordinated 003 cutover; additive columns then constraints (recoverable, backups per §9.2).	

#	Decision (source)	Options	Design recommendation + rationale	Blast-radius / reversibility	C
	Per-account signing-key rollout (owner 26_ §4; consumers 24_ §3, 25_ §5, 22_ §4.1)	(a) keep one global HELIX_ARTIFACT_PUBKEY; (b) per-account key registry + global fallback ; (c) TUF-style M-of-N thresholds (horizon)	(b) per-account ed25519 verify-key registry keyed on the resolved account_id, config-/KMS-backed, with the global key as a migration fallback ; the trust boundary is unchanged (verify key from server config/registry only, never the request — only the <i>lookup key</i> gains an account dimension). Device side verifies against its account's key provisioned at enrollment from server config. TUF thresholds noted as the hardening horizon (§11.4.112), not built now.	Moderate; staged behind the global fallback (additive, reversible per account). A shared global key is unacceptable long-term (any signer signs for the platform).	T n c a s s a s

2.1 Additional recommendation-with-tradeoffs decisions the set surfaces (secondary)

These are already recommended-with-tradeoffs in the owner docs (not open contradictions); listed so the approval gate is complete. Each is reversible/additive along its recommended path.

Decision (owner)	Recommended path	Alternative (condition to flip)
Sign-in split (23_ §1.2)	Option A — one form, post-auth role routing	Option B (physically separate super-admin door + stronger MFA) if the

Decision (owner)	Recommended path	Alternative (condition to flip)
CLI key auth (24_ §1.3)	Option B — key is an exchange credential (short-lived scoped token)	operator wants a separate console Option A (direct-key Bearer) if the tenant claim is out of scope for milestone 1
Device enrollment (25_ §1.3, 22_ §4.2)	Option A — operator-minted scoped token	Option B (bootstrap-claim → per-device token) for self-service / fleet scale
Cross-tenant denial response (22_ §6.2; hard rule deferred to 26_)	404 (anti-enumeration) for cross-account; 403 for in-account role gaps	403 throughout if diagnostic clarity is preferred — 26_ binds the final rule
Dev-secret handling (26_ §3.4/§6)	Fail-fast on unset <code>HELIX_TOKEN_SECRET</code> in a multi-account build	(none recommended — the predictable dev fallback <code>config.go:180-184</code> is a tenant-isolation break multi-tenant)

3. No-divergence verdict

Verdict: CONDITIONAL PASS — internally consistent AFTER two blocking reconciliations land; three low-risk RECONCILE items should follow.

The set is **internally consistent** on every mandated cross-check where it matters most: the **token claim set** (A), **account-scoping approach** (F), **role vocabulary at the doc level** (E), the **Account shape** (B), and **per-account signing keys** (G) all agree across every doc that touches them, and the two framing tensions that could have diverged — 20_’s “resolve-per-request” vs “stamp-claim” (reconciled in 21_ §2.2) and 23_’s “replace ProjectAccess?” (resolved in 21_ §2.3, both layers coexist) — were **already reconciled in-doc**. The role-vocabulary and "developer"-literal issues are **codebase** fixes owned by 21_ §5 / flagged by 23_ §5, not doc-to-doc contradictions.

Two residual divergences MUST be fixed before implementation (they are genuine “same tracked data, two divergent representations” of the §11.4.186 class):

1. **#H — add `api_keys.project_id` (nullable) to `20_ $4`.** Three docs (21_ \$6.1, 22_ \$4.1, 24_ \$1.1) rely on a scope column the SSOT DDL omits.
2. **#J — reconcile legacy-token handling: align 22_ \$6.1 to 21_ \$3.3 (fail-closed).** The two docs prescribe opposite security postures for a legacy no-account-claim token; 22_ cedes authZ to 21_, so fail-closed wins and the token → `__default__` fallback is struck.

Three low-risk RECONCILE items should be applied in the same sweep (non-blocking but divergence-eliminating): #D (23_ AccountAccess → 20_ AccountMembership), #I (24_ id → 20_ api_key_id), #L (single canonical resolvePublicKey line range); plus the #C UI-User field note. With #H and #J fixed and #D/#I/#L/#C applied, the set carries **no residual cross-document divergence** and is ready for the operator approval gate.

Honest boundary (§11.4.6)

- **This proves internal CONSISTENCY, not plan CORRECTNESS (§11.4.186 boundary).** The verdict certifies that the docs do not contradict each other about the same tracked data after the named fixes — it does **NOT** certify that the shared-schema+RLS model, the RBAC-first hybrid, the default-account backfill, or the per-account key registry are the *right* choices, achievable on the target timeline, or free of design flaws. Those remain operator/management + implementation-review decisions the register **surfaces**, never makes.
- **This is a reconciliation report, not a rewrite.** Per the task and §11.4.186, no source doc (20_...27_) was edited; the recommended alignments (#H amend 20_ \$4, #J align 22_ \$6.1 to 21_ \$3.3, #D/#I/#L/#C) are **proposals for the owner docs**, to be applied by their owners before implementation — this file only records them.
- **Grounding scope.** Every divergence claim is grounded in a doc §section (or a file:line those docs established). The underlying file:line facts (e.g. `api-client.ts:323`, `dashboard/src/types/api.ts:12`, `sidebar.tsx:20-21`, `handlers_artifact.go` ranges, 20_ \$4 DDL lines) are **inherited from the eight docs as they cite them** and were not independently re-read against source under this task — a citation the source docs got wrong would propagate here (the

docs' own §11.4.6 boundaries note their file:line set was established against non-test source only).

- **21_ / 26_ were authored after 20_ and cite it; 23_/24_/25_ predate it and self-mark their shapes illustrative** — so most pre-SSOT divergences are already soft-committed to reconcile. The two RESIDUAL-BLOCKING items (#H, #J) are the exceptions: #H is a **gap in the SSOT itself** (not a pre-SSOT drift), and #J is a **post-SSOT contradiction between two docs that both cite 20_** — exactly the class that survives “authored-after-SSOT” and needs the explicit gate this report provides.
- **No new external research** was performed (this is a §11.4.186 internal cross-document pass, not a §11.4.99 latest-source verification); all five docs' ## Sources verified 2026-07-10 footers stand as authored.